

1. PLAN DE RESPUESTA A INCIDENTES: IDENTIFICACIÓN (TECHCO)

1.1. INVENTARIO Y CLASIFICACIÓN DE ACTIVOS AFECTADOS

Aquí listamos los sistemas comprometidos y evaluamos el impacto en el negocio utilizando la tríada **CIA** (Confidencialidad, Integridad y Disponibilidad), enfocándonos en la pérdida de **Disponibilidad** (cifrado) y riesgo de **Confidencialidad** (exfiltración).

Activo Crítico	Descripción del Impacto	Nivel de Criticidad
Servidor de Archivos	Almacena documentos operativos diarios. Su cifrado paraliza la operación administrativa y la continuidad del negocio.	Alta
Base de Datos de Clientes	Contiene información personal y financiera sensible. Su compromiso expone a TechCo a demandas legales, multas regulatorias y daño reputacional masivo.	Crítica
Sistemas de Backup Internos	La última línea de defensa. Al estar cifrados, eliminan la capacidad de recuperación inmediata, forzando a la empresa a un escenario de pérdida total de datos.	Crítica

1.2. ANÁLISIS DE VULNERABILIDADES EXPLOTADAS

El ataque no fue magia; ocurrió porque existían debilidades vectoriales. Identificamos tres fallas principales en TechCo:

- **Vulnerabilidad Humana (Phishing Colectivo):** Falta de concientización y cultura de seguridad en los empleados. El vector inicial fue la ejecución de un adjunto malicioso (factura.exe o macros maliciosas) debido a la incapacidad del usuario para reconocer un correo fraudulento.
- **Vulnerabilidad Técnica en Endpoint y Correo:** Ausencia de herramientas de filtrado perimetral de correo (Secure Email Gateway - SEG) que bloquearan el correo de phishing, y falta de políticas de restricción de ejecución en el sistema operativo del empleado (lo que permitió que el adjunto corriera el código del ransomware).
- **Vulnerabilidad de Arquitectura (Ausencia de Segmentación):** Una red plana sin zonas de seguridad desbordadas. Al no haber Firewalls internos ni listas de control de acceso (ACLs), el ransomware utilizó protocolos de red estándar (como SMB/Windows Shares) para autorreplicarse horizontalmente desde la laptop del empleado hacia los servidores y los backups.

1.3. EVALUACIÓN DEL IMPACTO FINANCIERO Y OPERACIONAL

- **Tiempo de Inactividad (Downtime):** Operación en la nube completamente detenida o severamente degradada debido al cifrado de la base de datos de clientes.
- **Secuestro de Datos (Ransom):** Extorsión directa de 50 Bitcoins (más de \$1,000,000 USD) bajo la amenaza de destrucción total de la información en un plazo estricto de 72 horas.
- **Riesgo Regulatorio:** Potencial fuga o exfiltración de datos financieros de clientes, lo que podría violar normativas de protección de datos (como GDPR o equivalentes locales).

2. PLAN DE RESPUESTA A INCIDENTES: PROTECCIÓN (TECHCO)

2.1. INGENIERÍA Y ARQUITECTURA DE RED SEGURA

El mayor error de TechCo fue permitir la libre propagación del ransomware. Para evitar que un compromiso en un equipo de usuario llegue a los servidores críticos, se deben implementar las siguientes medidas:

- **Segmentación de Red (Zero Trust):** Dividir la infraestructura en zonas de seguridad aisladas mediante VLANs y Firewalls de Nueva Generación (NGFW). La red de empleados de oficina debe estar completamente separada de la red de producción (servidores y bases de datos).
- **Aislamiento de la Zona de Backups:** Los sistemas de respaldo deben residir en una VLAN muy restringida. Ningún equipo de la red corporativa regular debe tener acceso directo a esta zona; solo los agentes de software autorizados y mediante puertos estrictamente específicos.
- **Control de Tráfico Lateral:** Bloquear por defecto el tráfico de red directo entre estaciones de trabajo (comunicación *peer-to-peer*). Si los atacantes comprometen una laptop, no podrán saltar a la del compañero de al lado.

2.2. ESTRATEGIA DE RESPALDOS INMUNES (PROTECCIÓN DE DATOS)

Dado que los backups de TechCo fueron cifrados, la estrategia de continuidad debe rediseñarse bajo estándares modernos:

- **Regla 3-2-1-1-0:**
 - Mantener al menos **3** copias de los datos.
 - Almacenadas en **2** tipos de soporte diferentes (ej. disco local y nube).
 - **1** copia fuera de las instalaciones (Offsite).
 - **1** copia que sea completamente **Offline / Air-Gapped** (desconectada físicamente de la red corporativa cuando no se usa).
 - **0** errores, mediante la verificación automatizada de la restauración de los backups.
- **Inmutabilidad de Datos (WORM):** Configurar repositorios de almacenamiento que soporten políticas de "Escribir una vez, leer muchas" (*Write Once, Read Many*). Durante un periodo de tiempo definido, los backups inmutables no pueden ser modificados, sobrescritos ni eliminados por nadie, ni siquiera por un administrador con credenciales robadas.

2.3. SEGURIDAD EN EL VECTOR DE ENTRADA (CORREO Y ENDPOINT)

Para detener el phishing antes de que llegue a la bandeja de entrada del empleado:

- **Implementación de un SEG (Secure Email Gateway):** Un filtro perimetral de correo que analice los adjuntos en un entorno seguro aislado (*Sandbox*) antes de entregarlos al usuario. Esto habría bloqueado la factura maliciosa de TechCo.
- **Hardening del Sistema Operativo y Mínimo Privilegio:**
 - Quitar los permisos de administrador local a todos los empleados ordinarios.
 - Bloquear por política de grupo (GPO) la ejecución de macros en documentos de Office y scripts no firmados (como .bat, .ps1, .vbs).
 - Implementar el control de aplicaciones permitidas (*Application Whitelisting*).

2.4. CONCIENTIZACIÓN Y CAPACITACIÓN (EL FACTOR HUMANO)

Programas de Simulación de Phishing: Realizar campañas mensuales de phishing simulado no punitivas. Los usuarios que caigan en la trampa recibirán micro-capacitaciones inmediatas de 5 minutos sobre cómo identificar remitentes sospechosos o extensiones de archivos falsas.

3. PLAN DE RESPUESTA A INCIDENTES: DETECCIÓN (TECHCO)

El objetivo de esta fase es implementar una visibilidad continua y mecanismos de alerta temprana que permitan identificar actividades anómalas o maliciosas en tiempo real. Pasaremos de un modelo reactivo a uno proactivo.

3.1. ARQUITECTURA DE MONITOREO Y HERRAMIENTAS CLAVE

Para que TechCo recupere la visibilidad de su entorno, se propone el despliegue de tres soluciones tecnológicas esenciales:

- **EDR (Endpoint Detection and Response):** Desplegar agentes de EDR en todas las estaciones de trabajo y servidores. A diferencia de un antivirus tradicional que busca firmas conocidas, el EDR analiza el *comportamiento*. Si una laptop empieza a modificar o renombrar cientos de archivos por minuto (patrón típico de cifrado), el EDR lo detecta y aísla el equipo automáticamente.
- **SIEM (Security Information and Event Management):** Implementar una plataforma centralizada para recolectar, correlacionar y almacenar los logs (registros de actividad) de toda la empresa: firewalls, servidores, controladores de dominio y sistemas de correo.
- **IDS/IPS de Red (Intrusion Detection/Prevention System):** Colocar sensores en los puntos de convergencia de la red (especialmente entre la red de usuarios y la zona de servidores) para inspeccionar el tráfico en busca de movimientos laterales sospechosos o descargas de herramientas de hackeo.

3.2. REGLAS DE CORRELACIÓN E INDICADORES DE COMPROMISO (IOCS)

Para activar las alarmas en el SIEM, configuraremos reglas específicas enfocadas en las etapas tempranas de un ataque de ransomware:

- **Detección de Phishing Activo:** Alertas automatizadas cuando un usuario reciba un correo de un dominio de reciente creación (menos de 30 días) o con adjuntos con doble extensión (ej. factura.pdf.exe).
- **Alerta de Cifrado Masivo (Comportamiento en Disco):** Reglas en el EDR que disparen una alerta de severidad crítica si un proceso no autorizado realiza más de 20 modificaciones de archivos (operaciones de escritura/renombrado) en un lapso menor a 10 segundos.
- **Uso Anómalo de Herramientas de Administración:** Monitorear el uso de comandos del sistema que los atacantes usan para propagarse o deshabilitar defensas (ej. ejecuciones sospechosas de PowerShell, vssadmin.exe delete shadows para borrar copias ocultas de Windows, o comandos de net use para mapear redes de forma masiva).
- **Conexiones a Redes de Comando y Control (C2):** Alertas en el Firewall cuando un endpoint interno intente comunicarse con direcciones IP clasificadas como maliciosas o intente realizar peticiones DNS extrañas hacia la red Tor o servicios de almacenamiento anónimos (donde los atacantes suelen subir los datos robados).

3.3. PROTOCOLO DE ALERTA TEMPRANA Y CLASIFICACIÓN DE INCIDENTES

TechCo necesita un flujo claro para que una alerta no se quede olvidada en una bandeja de entrada. Se establece el siguiente sistema de priorización (Triage):

Nivel de Alerta	Criterio de Detección	Acción Inmediata
Baja	Intento bloqueado de conexión a IP sospechosa desde una laptop.	Registro en log y revisión rutinaria en las próximas 24 horas.
Media	Ejecución de un script de PowerShell no firmado en un equipo de usuario.	Investigación activa por un analista de seguridad (máximo 1 hora).
Alta / Crítica	Ejecución de procesos modificando múltiples archivos en un servidor O alertas de borrado de Shadow Copies.	Activación automática del Playbook de Ransomware y aislamiento inmediato del host afectado.

4. PLAN DE RESPUESTA A INCIDENTES: RESPUESTA (TECHCO)

El objetivo de esta fase es reaccionar de forma rápida y coordinada ante la confirmación del incidente de ransomware, priorizando la **contención** para detener el daño, la **erradicación** de la amenaza y la **gestión de la crisis** a nivel institucional.

4.1. ESTRUCTURA DEL EQUIPO DE RESPUESTA (CSIRT)

Se establece el Equipo de Respuesta a Incidentes de Seguridad Informática (CSIRT) de TechCo con roles y responsabilidades exclusivas durante la crisis:

- **Comandante del Incidente (Incident Commander / CISO):** Dirige la estrategia general, autoriza medidas drásticas (como apagar sistemas de producción) y coordina el flujo de información hacia la alta gerencia.
- **Analistas Técnicos de Seguridad (SOC / SysAdmins):** Encargados de ejecutar el aislamiento de redes, análisis forense de memoria/logs, e identificación del malware.
- **Asesor Legal:** Evalúa las implicaciones de la pérdida de confidencialidad de la base de datos de clientes (leyes de privacidad, multas regulatorias y obligaciones de notificación de brechas).
- **Coordinador de Comunicaciones (Relaciones Públicas):** Única persona autorizada para emitir declaraciones internas (a empleados) y externas (a clientes y prensa), evitando filtraciones que dañen la reputación.

4.2. PROTOCOLO DE EJECUCIÓN TÉCNICA (PLAYBOOK DE RANSOMWARE)

Una vez que la fase de Detección enciende la alarma crítica, el equipo técnico ejecutará el siguiente procedimiento de emergencia de forma secuencial:

1. Contención de Red Inmediata: Minutos 1-15.

Aislar de la red (desconectar cables Ethernet, desactivar interfaces de red virtuales en el hipervisor vSphere/Nutanix) todos los servidores afectados (Archivos, BD y Backups) y la laptop de origen. **Prohibido apagar los equipos bruscamente** para no destruir la memoria RAM, donde residen las llaves de cifrado y los procesos activos del malware.

2. Bloqueo de Identidades: Minutos 15-30.

Deshabilitar de forma temporal el árbol de cuentas de Active Directory / Entra ID que estuvieron involucradas en el compromiso, incluyendo la cuenta del usuario afectado y cualquier cuenta de servicio utilizada por el ransomware para el movimiento lateral.

3. Análisis Forense y Preservación: Horas 1-4.

Realizar un volcado de memoria RAM (*Memory Dump*) y clonado de discos de los sistemas afectados para su análisis posterior. Identificar el indicador de compromiso (IoC) original, la variante de ransomware (ej. LockBit, BlackCat) y buscar si existe un descifrador público disponible.

4. Erradicación de la Amenaza: Horas 4-12.

Identificar y eliminar todas las persistencias del atacante en la red (tareas programadas, llaves de registro modificadas, scripts de inicio). Escanear toda la infraestructura con herramientas de limpieza profunda para asegurar que no queden "puertas traseras" (*backdoors*).

4.3. ESTRATEGIA DE COMUNICACIÓN E INCIDENT HANDLING

TechCo gestiona datos confidenciales en la nube; por ende, la comunicación es un campo minado legal y comercial.

- **Comunicación Interna:** Notificar a todo el personal de TechCo sobre la desconexión temporal de sistemas utilizando un canal alternativo seguro (como una red de mensajería corporativa fuera del dominio afectado o SMS). Instrucciones claras: *No encender equipos, no conectar unidades USB.*
- **Comunicación Externa (Clientes):** Diseñar un comunicado transparente pero controlado. Se notificará a los clientes afectados de la base de datos que sus servicios están en mantenimiento preventivo por un incidente de seguridad, garantizando que se está trabajando bajo estándares NIST.
- **Política de Pago del Rescate:** Se establece una política estricta de **NO PAGAR LOS 50 BITCOINS.** Siguiendo las directrices del FBI y agencias internacionales de ciberseguridad, pagar no garantiza la devolución de los datos, financia el crimen organizado y convierte a TechCo en un blanco prioritario para futuros ataques.

5. PLAN DE RESPUESTA A INCIDENTES: RECUPERACIÓN (TECHCO)

El objetivo de esta fase es restaurar los sistemas y servicios afectados a su estado operativo normal de forma segura, validando que se encuentren libres de amenazas y garantizando la continuidad del negocio durante el proceso.

5.1. ESTRATEGIA DE RESTAURACIÓN SEGURA DE DATOS Y SISTEMAS

Debido a que los backups internos de producción fueron cifrados, TechCo debe ejecutar un protocolo extraordinario de restauración para evitar una reinfección:

- **Localización de Copias Limpias (Sanitizadas):** Se procederá a buscar el punto de restauración limpio más cercano en el tiempo utilizando los respaldos históricos o los backups *offsite/cloud* externos (que, según el nuevo plan de protección, debieron implementarse).
- **Aislamiento de la Zona de Reconstrucción (Sandbox de Recuperación):** Ningún servidor se restaurará directamente sobre la red de producción activa. Se levantarán primero en una red virtual completamente aislada de pruebas (*Sandbox*) para verificar su integridad.
- **Escaneo y Parcheo Pre-Producción:** Antes de reconectar la Base de Datos de Clientes y el Servidor de Archivos a la red principal, se realizarán tres acciones obligatorias en el entorno de pruebas:
 1. Pasar un escaneo profundo de malware con el EDR actualizado.
 2. Aplicar todos los parches de seguridad pendientes en el sistema operativo.
 3. Forzar el cambio masivo de contraseñas de todas las cuentas de servicio y de administrador.

5.2. PLAN DE CONTINUIDAD DEL NEGOCIO (BCP) EN MODO DEGRADADO

La reconstrucción total de los sistemas de TechCo puede tomar días. Para mitigar el impacto financiero y cumplir con los clientes de servicios en la nube, se activará el Plan de Continuidad:

- **Priorización de Servicios (RTO y RPO):**
 - **Objetivo de Tiempo de Recuperación (RTO):** Se establece un máximo de 24 horas para restablecer la Base de Datos de Clientes (crítica para el servicio en la nube) y 48 horas para el Servidor de Archivos.
 - **Objetivo de Punto de Recuperación (RPO):** Margen de pérdida de datos aceptable de máximo 12 horas previas al incidente.
- **Operación en "Modo Degradado":** Mientras los servidores principales regresan a línea, el equipo de soporte de TechCo utilizará instancias temporales limpias en la nube pública (infraestructura secundaria aislada) con datos estáticos previamente respaldados para mantener activos los portales web esenciales de los clientes en modo "Solo Lectura".

5.3. FASE DE TRANSICIÓN Y MONITOREO POST-INCIDENTE

El regreso a la normalidad operativa no es inmediato; requiere un periodo de observación preventiva para asegurar la estabilidad:

Paso de Transición	Acción Requerida	Responsable
1. Reconexión Gradual	Reintroducir los servidores a la red de uno en uno, comenzando por la base de datos de clientes.	Administrador de Sistemas
2. Monitoreo Intensivo	Activar alertas de telemetría de nivel "Verboso" (máximo detalle) en el SIEM y EDR durante los primeros 14 días para detectar cualquier intento de re-cifrado.	Analistas de SOC
3. Validación de Clientes	Confirmar con los usuarios clave que la integridad de los datos financieros y personales es correcta tras la restauración.	Gestión de Clientes (Account Managers)

6. PLAN DE RESPUESTA A INCIDENTES: MEJORA CONTINUA (TECHCO)

El objetivo de esta fase final es institucionalizar el aprendizaje derivado del incidente. El proceso de respuesta no termina cuando los sistemas vuelven a estar en línea, sino cuando se implementan los cambios necesarios para asegurar que el mismo vector de ataque jamás vuelva a ser efectivo.

6.1. REUNIÓN DE LECCIONES APRENDIDAS (ANÁLISIS POST-MORTEM)

En un plazo no mayor a **14 días hábiles** tras el cierre formal del incidente, el Comandante del Incidente convocará a una reunión obligatoria de revisión *Post-Mortem* con todos los miembros del CSIRT y la alta gerencia. Se documentarán las respuestas a las siguientes preguntas clave de NIST:

1. ¿Qué ocurrió exactamente y en qué momento? (Línea de tiempo oficial).
2. ¿Qué tan bien se desempeñó el equipo de respuesta y qué procedimientos del plan funcionaron o fallaron?
3. ¿Qué información crucial nos faltó en los primeros minutos del ataque y cómo podemos obtenerla la próxima vez?
4. ¿Qué acciones tempranas de los empleados o administradores obstaculizaron o ayudaron en la contención del ransomware?

6.2. MATRIZ DE ACCIONES CORRECTIVAS Y PLAN DE REMEDIACIÓN

Los fallos descubiertos durante el análisis se traducirán en un plan de acción con responsables directos y fechas límite estrictas para evitar el "olvido institucional":

Deficiencia Detectada	Acción Correctiva de Mejora	Prioridad	Plazo
El usuario ejecutó un adjunto malicioso por falta de conocimiento.	Lanzar un programa obligatorio de concientización en ciberseguridad y simulacros de phishing.	Alta	30 días
Los sistemas de backup internos fueron cifrados junto con la producción.	Migrar a una arquitectura de backups inmutables en la nube y aplicar aislamiento físico (Air-Gap).	Crítica	15 días
La propagación fue masiva debido a una red interna totalmente plana.	Ejecutar el proyecto de microsegmentación de red por VLANs y reglas estrictas en Firewalls internos.	Crítica	45 días
El ataque se detectó visualmente por los usuarios cuando ya todo estaba cifrado.	Configurar el EDR con alertas de heurística de disco y centralizar los logs críticos en el SIEM.	Alta	30 días

6.3. MÉTRICAS DE EFICACIA PARA EL MONITOREO FUTURO

Para evaluar si las mejoras implementadas están surtiendo efecto, TechCo comenzará a medir y reportar mensualmente a la junta directiva los siguientes Indicadores Clave de Rendimiento (KPIs):

- **MTTD (Mean Time to Detect / Tiempo Medio de Detección):** El tiempo que transcurre desde que el malware toca un endpoint hasta que salta la primera alerta en el SOC. Tras implementar el EDR y SIEM, la meta de TechCo debe ser reducir esto de **horas a minutos**.
- **MTTR (Mean Time to Respond / Tiempo Medio de Respuesta):** El tiempo que le toma al CSIRT aplicar el Playbook y aislar el dispositivo una vez detectado. El objetivo estratégico es automatizar la contención a través del EDR para que sea **instantánea**.
- **Tasa de Susceptibilidad al Phishing:** El porcentaje de empleados que hacen clic en los enlaces de las campañas de simulación mensuales. La meta es reducir este indicador por debajo del **5%** general en la empresa.